CyberScan
Security Audit Platform

google.com — Procédure de Résolution des Vulnérabilités

Informations générales

Information	Valeur
Date et heure du scan	26/07/2026 à 19:01
Identifiant unique du scan	124
Client	chaima

NIVEAU DE RISQUE : CRITIQUE
Score de risque IA : 8.6/10 — Score sécurité : 1.4/10

Le score sécurité est l'inverse du score de risque : plus il est bas, plus le niveau de vulnérabilité est élevé.

Sommaire

1. Situation actuelle

L'audit de google.com a identifié 4 vulnérabilité(s) significative(s). OS/versions détectés : Country (UNITED STATES), HTTPServer (gws), IP (172.217.18.110, 142.251.151.119), RedirectLocation (https://www.google.com/), Title (301 Moved, Google), UncommonHeaders (content-security-policy-report-only,alt-svc, content-security-policy-report-only,accept-ch,alt-svc), X-Frame-Options (SAMEORIGIN), X-XSS-Protection (0), Cookies (AEC, NID), HTML5, HttpOnly (AEC, NID), Script.

2. Méthodologie

SSLScan — Inventaire des protocoles et suites cryptographiques TLS.
Nmap — Détection des ports ouverts, services et bannières réseau.
OpenSSL — Contrôle de la négociation TLS et du certificat présenté.
WhatWeb — Identification des technologies et versions web.
OWASP ZAP — Analyse dynamique des contrôles de sécurité HTTP.
NVD — Corrélation des produits versionnés avec les CVE du NIST.

3. Inventaire technique

Technologies détectées

Technologie	Version	Détails
Country	—	UNITED STATES
HTTPServer	—	gws
IP	—	172.217.18.110, 142.251.151.119
RedirectLocation	—	https://www.google.com/
Title	—	301 Moved, Google
UncommonHeaders	—	content-security-policy-report-only,alt-svc, content-security-policy-report-only,accept-ch,alt-svc
X-Frame-Options	—	SAMEORIGIN
X-XSS-Protection	—	0
Cookies	—	AEC, NID, __Secure-STRP
HTML5	—	—
HttpOnly	—	AEC, NID
Script	—	—

Ports exposés

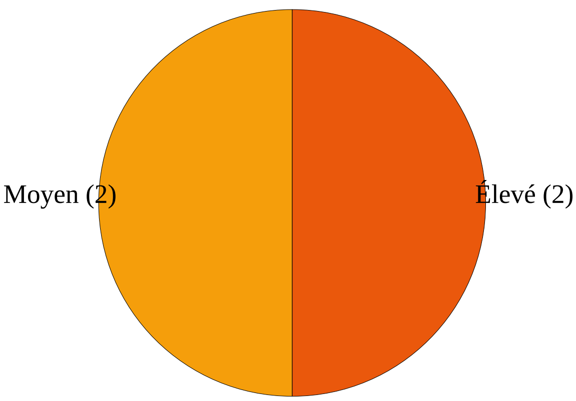
Port	État	Service	Classification
443/tcp	open	https	Standard

4. Indicateurs graphiques

Vue d’ensemble

IA **8.6/10** Score IA	**S** **14/100** Score sécurité dérivé	**!** **Critique** Niveau de risque	**V** **4** Constats prioritaires	**C** **0** Critiques
E **2** Élevées	**M** **2** Moyennes	**F** **0** Faibles	**CVE** **2** CVE détectées	**P** **1** Ports ouverts
SV **1** Services	**T** **12** Technologies	**O** **6** Outils avec résultats	**D** **Non disponible** Durée totale	

Niveau de risque	Critique	**Actions critiques**	2
Constats prioritaires	4	**Durée**	Non disponible
Recommandation principale	Désactiver TLS 1.0 et TLS 1.1 et n’autoriser que TLS 1.2/1.3.		



Répartition par sévérité

Total : 4

Jauge du score de risque IA

Élevé — engager rapidement les actions P1 et vérifier les actifs exposés.

Sécurité SSL/TLS et exposition réseau

Version TLS	Statut	Sécurité	Indicateur	Recommandation
TLS 1.0	Activé	Obsolète	X	Désactiver
TLS 1.1	Activé	Obsolète	X	Désactiver
TLS 1.2	Activé	Recommandé	OK	Maintenir activé
TLS 1.3	Activé	Optimal	OK	Maintenir activé

Protocoles SSL/TLS testés

Ports ouverts

Services détectés

Synthèse analytique

Statistique	Valeur	Statistique	Valeur
Adresse IP	Non disponible	**Certificats expirés**	Non disponible
Domaine	google.com	**Protocoles TLS testés**	4
Hébergeur	Non disponible	**Cipher Suites testées**	Non disponible
ASN	Non disponible	**Constats prioritaires**	4
Serveur Web	Non disponible	**CVE**	2
Technologies détectées	12	**CWE**	Non disponible
Ports ouverts	1	**Outils avec résultats**	6
Services détectés	1	**Temps total du scan**	Non disponible
Certificats analysés	Non disponible	**Non disponible**	Non disponible

Analyse IA

Résumé des risques	Élevé — engager rapidement les actions P1 et vérifier les actifs exposés.
Vulnérabilités prioritaires	TLSv1.0 / TLSv1.1, Suites de chiffrement faibles (3DES/RC4)
Causes probables	Configuration
Conséquences possibles	Compromission, interruption de service ou exposition de données possibles selon l'actif concerné.
Priorité de correction	P1 — immédiate
Gain estimé après remédiation	Non disponible
Recommandation principale	Désactiver TLS 1.0 et TLS 1.1 et n’autoriser que TLS 1.2/1.3.

Posture de sécurité

Domaine de sécurité	Score	Posture
TLS Security	50 %	
SSL Certificate	Non disponible	Non disponible
Web Server Configuration	Non disponible	Non disponible
HTTP Security Headers	Non disponible	Non disponible
Technologies Web	Non disponible	Non disponible
Vulnérabilités	Non disponible	Non disponible
Conformité	Non disponible	Non disponible

Bonnes pratiques et conformité

Élément	État actuel	Bonne pratique	Statut
TLS 1.0	Activé	Désactivé	X
TLS 1.1	Activé	Désactivé	X
TLS 1.2	Activé	Activé	OK
TLS 1.3	Activé	Activé	OK
Certificat SSL	Non disponible	Valide et non expiré	—
En-têtes HTTP	Non disponible	Contrôles requis présents	—

Référentiel	Niveau	Indicateur
OWASP Top 10	Non disponible	—
NIST CSF	Non disponible	—
ISO 27001	Non disponible	—
PCI DSS	Non disponible	—
ANSSI	Non disponible	—

5. Fiches vulnérabilité

Vuln_001

Libellé	Valeur
Identifiant	Vuln_001
Composant vulnérable	TLSv1.0 / TLSv1.1
Preuve d'audit	TLSv1.0 enabled TLSv1.1 enabled TLSv1.1 not vulnerable to heartbleed TLSv1.0 not vulnerable to heartbleed
Type	Configuration
Actif impacté	google.com
Score CVSS	7.5
Niveau de criticité	Élevé
Recommandation	Désactiver TLS 1.0 et TLS 1.1 et n'autoriser que TLS 1.2/1.3.
Priorité de mise en œuvre	Immédiate

Solution proposée :

1. Nginx : définir « ssl_protocols TLSv1.2 TLSv1.3; » dans le bloc serveur.
2. Apache : définir « SSLProtocol -all +TLSv1.2 +TLSv1.3 » puis recharger le service.
3. Vérifier avec « openssl s_client -connect <hôte>:443 -tls1 » puis relancer sslscan.

Vuln_002

Libellé	Valeur
Identifiant	Vuln_002
Composant vulnérable	Suites de chiffrement faibles (3DES/RC4)
Preuve d'audit	Accepted TLSv1.2 112 bits TLS_RSA_WITH_3DES_EDE_CBC_SHA Accepted TLSv1.1 112 bits TLS_RSA_WITH_3DES_EDE_CBC_SHA Accepted TLSv1.0 112 bits TLS_RSA_WITH_3DES_EDE_CBC_SHA
Type	Configuration
Actif impacté	google.com

Libellé	Valeur
Score CVSS	7.5
Niveau de criticité	Élevé
Recommandation	Retirer 3DES et RC4 de la liste des suites cryptographiques autorisées.
Priorité de mise en œuvre	Immédiate

Solution proposée :

1. Nginx : utiliser « ssl_ciphers HIGH:!aNULL:!MD5:!3DES:!RC4; ».
2. Apache : utiliser « SSLCipherSuite HIGH:!aNULL:!MD5:!3DES:!RC4 » puis recharger le service.
3. Relancer « sslscan <hôte> » et confirmer l'absence de 3DES/RC4.

Vuln_003

Libellé	Valeur
Identifiant	Vuln_003
Composant vulnérable	En-tête Content-Security-Policy (CSP) absent
Preuve d'audit	ZAP [Medium] En-tête Content-Security-Policy (CSP) absent URL : https://google.com Occurrences : 1
Type	Technique
Actif impacté	https://google.com
Score CVSS	5.0
Niveau de criticité	Moyen
Recommandation	Configurer explicitement l'en-tête HTTP Content-Security-Policy sur toutes les réponses.
Priorité de mise en œuvre	Court terme

Solution proposée :

1. Nginx : add_header Content-Security-Policy "default-src 'self'; object-src 'none'; frame-ancestors 'self'" always;
2. Apache : Header always set Content-Security-Policy "default-src 'self'; object-src 'none'; frame-ancestors 'self'"
3. Vérifier avec « curl -I https://<hôte> » que Content-Security-Policy est présent.

Vuln_004

Libellé	Valeur
Identifiant	Vuln_004
Composant vulnérable	Attribut Subresource Integrity (SRI) absent
Preuve d'audit	ZAP [Medium] Attribut Subresource Integrity (SRI) absent URL : https://google.com Occurrences : 2

Libellé	Valeur
Type	Technique
Actif impacté	https://google.com
Score CVSS	5.0
Niveau de criticité	Moyen
Recommandation	Fournir un attribut integrity valide sur chaque balise script ou link chargée depuis un tiers.
Priorité de mise en œuvre	Court terme

Solution proposée :

1. Nginx : déployer la balise « <script src="/app.js" integrity="sha384-..." crossorigin="anonymous"></script> » dans le fichier HTML servi.
2. Apache : déployer la même balise SRI dans le document servi par le VirtualHost.
3. Générer le hash avec « openssl dgst -sha384 -binary fichier.js | openssl base64 -A », puis vérifier dans la console du navigateur.

■ Plan de correction

Priorité	Élément	Action corrective
P1	—	Désactiver TLS 1.0 et TLS 1.1 et n'autoriser que TLS 1.2/1.3.
P1	CVE-2016-2183	Retirer 3DES et RC4 de la liste des suites cryptographiques autorisées.
P2	—	Configurer explicitement l'en-tête HTTP Content-Security-Policy sur toutes les réponses.
P2	—	Fournir un attribut integrity valide sur chaque balise script ou link chargée depuis un tiers.

■ Annexe CVE

CVE / Élément	CVSS	Description
—	—	Aucune autre CVE pertinente après filtrage.

6. Conclusion

Le score sécurité est de 1.4/10, pour un risque critique (8.6/10). Appliquer les actions P1/P2 puis relancer CyberScan.

CYBERSCAN • SECURITY AUDIT PLATFORM •

RAPPORT CERTIFIÉ

Scan #124

Document généré et certifié automatiquement
par la plateforme CyberScan.

■ Annexe — sorties brutes complètes

SSLScan

```
Version: 2.1.5
OpenSSL 3.5.6 7 Apr 2026

Connected to 172.217.18.110

Testing SSL server google.com on port 443 using SNI name google.com

SSL/TLS Protocols:
SSLv2 disabled
SSLv3 disabled
TLSv1.0 enabled
TLSv1.1 enabled
TLSv1.2 enabled
TLSv1.3 enabled

TLS Fallback SCSV:
Server supports TLS Fallback SCSV

TLS renegotiation:
Secure session renegotiation supported

TLS Compression:
Compression disabled

Heartbleed:
TLSv1.3 not vulnerable to heartbleed
TLSv1.2 not vulnerable to heartbleed
TLSv1.1 not vulnerable to heartbleed
TLSv1.0 not vulnerable to heartbleed

Supported Server Cipher(s):
Preferred TLSv1.3 128 bits TLS_AES_128_GCM_SHA256
Accepted TLSv1.3 256 bits TLS_AES_256_GCM_SHA384
Accepted TLSv1.3 256 bits TLS_CHACHA20_POLY1305_SHA256
Preferred TLSv1.2 256 bits ECDHE-ECDSA-CHACHA20-POLY1305 Curve 25519 DHE 253
Accepted TLSv1.2 128 bits ECDHE-ECDSA-AES128-GCM-SHA256 Curve 25519 DHE 253
Accepted TLSv1.2 256 bits ECDHE-ECDSA-AES256-GCM-SHA384 Curve 25519 DHE 253
Accepted TLSv1.2 128 bits ECDHE-ECDSA-AES128-SHA Curve 25519 DHE 253
Accepted TLSv1.2 256 bits ECDHE-ECDSA-AES256-SHA Curve 25519 DHE 253
Accepted TLSv1.2 256 bits ECDHE-RSA-CHACHA20-POLY1305 Curve 25519 DHE 253
Accepted TLSv1.2 128 bits ECDHE-RSA-AES128-GCM-SHA256 Curve 25519 DHE 253
Accepted TLSv1.2 256 bits ECDHE-RSA-AES256-GCM-SHA384 Curve 25519 DHE 253
Accepted TLSv1.2 128 bits ECDHE-RSA-AES128-SHA Curve 25519 DHE 253
Accepted TLSv1.2 256 bits ECDHE-RSA-AES256-SHA Curve 25519 DHE 253
Accepted TLSv1.2 128 bits AES128-GCM-SHA256
Accepted TLSv1.2 256 bits AES256-GCM-SHA384
Accepted TLSv1.2 128 bits AES128-SHA
Accepted TLSv1.2 256 bits AES256-SHA
Accepted TLSv1.2 112 bits TLS_RSA_WITH_3DES_EDE_CBC_SHA
Preferred TLSv1.1 128 bits ECDHE-ECDSA-AES128-SHA Curve 25519 DHE 253
Accepted TLSv1.1 256 bits ECDHE-ECDSA-AES256-SHA Curve 25519 DHE 253
Accepted TLSv1.1 128 bits ECDHE-RSA-AES128-SHA Curve 25519 DHE 253
Accepted TLSv1.1 256 bits ECDHE-RSA-AES256-SHA Curve 25519 DHE 253
Accepted TLSv1.1 128 bits AES128-SHA
Accepted TLSv1.1 256 bits AES256-SHA
Accepted TLSv1.1 112 bits TLS_RSA_WITH_3DES_EDE_CBC_SHA
Preferred TLSv1.0 128 bits ECDHE-ECDSA-AES128-SHA Curve 25519 DHE 253
Accepted TLSv1.0 256 bits ECDHE-ECDSA-AES256-SHA Curve 25519 DHE 253
Accepted TLSv1.0 128 bits ECDHE-RSA-AES128-SHA Curve 25519 DHE 253
Accepted TLSv1.0 256 bits ECDHE-RSA-AES256-SHA Curve 25519 DHE 253
Accepted TLSv1.0 128 bits AES128-SHA
Accepted TLSv1.0 256 bits AES256-SHA
Accepted TLSv1.0 112 bits TLS_RSA_WITH_3DES_EDE_CBC_SHA

Server Key Exchange Group(s):
TLSv1.3 128 bits secp256r1 (NIST P-256)
TLSv1.3 128 bits x25519
TLSv1.2 128 bits secp256r1 (NIST P-256)
```

```
TLSv1.2 128 bits x25519
```

```
SSL Certificate:
Signature Algorithm: sha256WithRSAEncryption
ECC Curve Name: prime256v1
ECC Key Strength: 128

Subject: *.google.com
Altnames: DNS:*.google.com, DNS:*.appengine.google.com, DNS:*.bdn.dev, DNS:*.origin-test.bdn.dev,
DNS:*.cloud.google.com, DNS:*.crowdsource.google.com, DNS:*.datacompute.google.com, DNS:*.google.ca,
DNS:*.google.cl, DNS:*.google.co.in, DNS:*.google.co.jp, DNS:*.google.co.uk, DNS:*.google.com.ar,
DNS:*.google.com.au, DNS:*.google.com.br, DNS:*.google.com.co, DNS:*.google.com.mx, DNS:*.google.com.tr,
DNS:*.google.com.vn, DNS:*.google.de, DNS:*.google.es, DNS:*.google.fr, DNS:*.google.hu, DNS:*.google.it,
DNS:*.google.nl, DNS:*.google.pl, DNS:*.google.pt, DNS:*.gemini.cloud.google.com, DNS:*.gstatic.com,
DNS:*.metric.gstatic.com, DNS:*.gvt1.com, DNS:*.gcpcdn.gvt1.com, DNS:*.gvt2.com, DNS:*.gcp.gvt2.com,
DNS:*.url.google.com, DNS:*.youtube-nocookie.com, DNS:*.ytimg.com, DNS:ai.android, DNS:android.com,
DNS:*.android.com, DNS:*.flash.android.com, DNS:g.co, DNS:*.g.co, DNS:goo.gl, DNS:www.goo.gl,
DNS:google-analytics.com, DNS:*.google-analytics.com, DNS:google.com, DNS:googlecommerce.com,
DNS:*.googlecommerce.com, DNS:urchin.com, DNS:*.urchin.com, DNS:youtu.be, DNS:youtube.com, DNS:*.youtube.com,
DNS:music.youtube.com, DNS:*.music.youtube.com, DNS:youtubeeducation.com, DNS:*.youtubeeducation.com,
DNS:youtubekids.com, DNS:*.youtubekids.com, DNS:yt.be, DNS:*.yt.be, DNS:android.clients.google.com,
DNS:*.aistudio.google.com
Issuer: WR2

Not valid before: Jun 29 08:37:25 2026 GMT
Not valid after: Sep 21 08:37:24 2026 GMT
```

Nmap

```
Starting Nmap 7.95 ( https://nmap.org ) at 2026-07-26 19:58 CET
Nmap scan report for google.com (172.217.18.110)
Host is up (0.059s latency).
Other addresses for google.com (not scanned): 2a00:1450:4006:822::200e
rDNS record for 172.217.18.110: zrh04s05-in-f110.1e100.net

PORT STATE SERVICE
443/tcp open https
| ssl-enum-ciphers:
| TLSv1.0:
| ciphers:
| TLS_ECDHE_ECDSA_WITH_AES_128_CBC_SHA (ecdh_x25519) - A
| TLS_ECDHE_ECDSA_WITH_AES_256_CBC_SHA (ecdh_x25519) - A
| TLS_ECDHE_RSA_WITH_AES_128_CBC_SHA (ecdh_x25519) - A
| TLS_ECDHE_RSA_WITH_AES_256_CBC_SHA (ecdh_x25519) - A
| TLS_RSA_WITH_AES_128_CBC_SHA (rsa 2048) - A
| TLS_RSA_WITH_AES_256_CBC_SHA (rsa 2048) - A
| TLS_RSA_WITH_3DES_EDE_CBC_SHA (rsa 2048) - C
| compressors:
| NULL
| cipher preference: server
| warnings:
| 64-bit block cipher 3DES vulnerable to SWEET32 attack
| TLSv1.1:
| ciphers:
| TLS_ECDHE_ECDSA_WITH_AES_128_CBC_SHA (ecdh_x25519) - A
| TLS_ECDHE_ECDSA_WITH_AES_256_CBC_SHA (ecdh_x25519) - A
| TLS_ECDHE_RSA_WITH_AES_128_CBC_SHA (ecdh_x25519) - A
| TLS_ECDHE_RSA_WITH_AES_256_CBC_SHA (ecdh_x25519) - A
| TLS_RSA_WITH_AES_128_CBC_SHA (rsa 2048) - A
| TLS_RSA_WITH_AES_256_CBC_SHA (rsa 2048) - A
| TLS_RSA_WITH_3DES_EDE_CBC_SHA (rsa 2048) - C
| compressors:
| NULL
| cipher preference: server
```

```
| warnings:
| 64-bit block cipher 3DES vulnerable to SWEET32 attack
| TLSv1.2:
| ciphers:
| TLS_ECDHE_ECDSA_WITH_AES_128_CBC_SHA (ecdh_x25519) - A
| TLS_ECDHE_ECDSA_WITH_AES_128_GCM_SHA256 (ecdh_x25519) - A
| TLS_ECDHE_ECDSA_WITH_AES_256_CBC_SHA (ecdh_x25519) - A
| TLS_ECDHE_ECDSA_WITH_AES_256_GCM_SHA384 (ecdh_x25519) - A
```

```
| TLS_ECDHE_ECDSA_WITH_CHACHA20_POLY1305_SHA256 (ecdh_x25519) - A
| TLS_ECDHE_RSA_WITH_AES_128_CBC_SHA (ecdh_x25519) - A
| TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256 (ecdh_x25519) - A
| TLS_ECDHE_RSA_WITH_AES_256_CBC_SHA (ecdh_x25519) - A
| TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384 (ecdh_x25519) - A
| TLS_ECDHE_RSA_WITH_CHACHA20_POLY1305_SHA256 (ecdh_x25519) - A
| TLS_RSA_WITH_3DES_EDE_CBC_SHA (rsa 2048) - C
| TLS_RSA_WITH_AES_128_CBC_SHA (rsa 2048) - A
| TLS_RSA_WITH_AES_128_GCM_SHA256 (rsa 2048) - A
| TLS_RSA_WITH_AES_256_CBC_SHA (rsa 2048) - A
| TLS_RSA_WITH_AES_256_GCM_SHA384 (rsa 2048) - A
| compressors:
| NULL
| cipher preference: client
| warnings:
| 64-bit block cipher 3DES vulnerable to SWEET32 attack
| TLSv1.3:
| ciphers:
| TLS_AKE_WITH_AES_128_GCM_SHA256 (ecdh_x25519) - A
| TLS_AKE_WITH_AES_256_GCM_SHA384 (ecdh_x25519) - A
| TLS_AKE_WITH_CHACHA20_POLY1305_SHA256 (ecdh_x25519) - A
| cipher preference: client
|_ least strength: C

Nmap done: 1 IP address (1 host up) scanned in 4.97 seconds
```

OpenSSL

```
Connecting to 172.217.18.110
depth=2 C=US, O=Google Trust Services LLC, CN=GTS Root R1
verify return:1
depth=1 C=US, O=Google Trust Services, CN=WR2
verify return:1
depth=0 CN=*.google.com
verify return:1
CONNECTED(00000003)
---
Certificate chain
0 s:CN=*.google.com
i:C=US, O=Google Trust Services, CN=WR2
a:PKEY: EC, (prime256v1); sigalg: sha256WithRSAEncryption
v:NotBefore: Jun 29 08:37:25 2026 GMT; NotAfter: Sep 21 08:37:24 2026 GMT
1 s:C=US, O=Google Trust Services, CN=WR2
i:C=US, O=Google Trust Services LLC, CN=GTS Root R1
a:PKEY: RSA, 2048 (bit); sigalg: sha256WithRSAEncryption
v:NotBefore: Dec 13 09:00:00 2023 GMT; NotAfter: Feb 20 14:00:00 2029 GMT
2 s:C=US, O=Google Trust Services LLC, CN=GTS Root R1
i:C=BE, O=GlobalSign nv-sa, OU=Root CA, CN=GlobalSign Root CA
a:PKEY: RSA, 4096 (bit); sigalg: sha256WithRSAEncryption
v:NotBefore: Jun 19 00:00:42 2020 GMT; NotAfter: Jan 28 00:00:42 2028 GMT
---
Server certificate
-----BEGIN CERTIFICATE-----
```

```
MIIIdTCCB12gAwIBAgIQArDBmbXy/5YJXjyGGvQr7jANBgkqhkiG9w0BAQsFADA7
MQswCQYDVQQGEwJVUzEeMBwGA1UEChMVR29vZ2xlIFRydXN0IFNlcnZpY2VzMQww
CgYDVQQDEwNXUjIwHhcNMjYwNjI5MDgzNzI1WhcNMjYwOTIxMDgzNzI0WjAXMRUw
EwYDVQQDDAwqLmdvb2dsZS5jb20wWTATBgcqhkjOPQIBBggqhkjOPQMBBwNCAASj
H70i8enSTNrvh0rvehNSVZXc8L6h1wUYYazISj4TKa+PT5i4Ta0r+FmN3jWEvf/s
nMTzB+VjraqhfwQAHO8fo4IGYjCCBl4wDgYDVR0PAQH/BAQDAgeAMBMGA1UdJQQM
MAoGCCsGAQUFBwMBMAwGA1UdEwEB/wQCMAAwHQYDVR0OBBYEFJUXUMxwSpWcIFwL
liPY18slkvAHMB8GA1UdIwQYMBaAFN4bHu15FdQ+NyTDIbvsNDltQrIwMFgGCCsG
AQUFBwEBBEwwSjAhBggrBgEFBQcwAYYVaHR0cDovL28ucGtpLmdvb2cvd3IyMCUG
CCsGAQUFBzAChhlodHRwOi8vaS5wa2kuZ29vZy93cjIuY3J0MIIEOAYDVR0RBIIE
```

```
LzCCBCuCDCouZ29vZ2xlLmNvbYIWKi5hcHBlbmdpbmUuZ29vZ2xlLmNvbYIJKi5i
ZG4uZGV2ghUqLm9yaWdpbi10ZXN0LmJkbi5kZXaCEiouY2xvdWQuZ29vZ2xlLmNv
bYIYKi5jcm93ZHNvdXJjZS5nb29nbGUuY29tghgqLmRhdGFjb21wdXRlLmdvb2ds
ZS5jb22CCyouZ29vZ2xlLmNhggsqLmdvb2dsZS5jbIIOKi5nb29nbGUuY28uaW6C
DiouZ29vZ2xlLmNvLmpwgg4qLmdvb2dsZS5jby51a4IPKi5nb29nbGUuY29tLmFy
gg8qLmdvb2dsZS5jb20uYXWCDyouZ29vZ2xlLmNvbS5icoIPKi5nb29nbGUuY29t
LmNvgg8qLmdvb2dsZS5jb20ubXiCDyouZ29vZ2xlLmNvbS50coIPKi5nb29nbGUu
Y29tLnZuggsqLmdvb2dsZS5kZYILKi5nb29nbGUuZXOCCyouZ29vZ2xlLmZyggsq
Lmdvb2dsZS5odYILKi5nb29nbGUuaXSCCyouZ29vZ2xlLm5sggsqLmdvb2dsZS5w
```

```
bIILKi5nb29nbGUucHSCGSouZ2VtaW5pLmNsb3VkLmdvb2dsZS5jb22CDSouZ3N0
YXRpYy5jb22CFCoubWV0cmljLmdzdGF0aWMuY29tggoqLmd2dDEuY29tghEqLmdj
cGNkbi5ndnQxLmNvbYIKKi5ndnQyLmNvbYIOKi5nY3AuZ3Z0Mi5jb22CECoudXJs
Lmdvb2dsZS5jb22CFioueW91dHViZS1ub2Nvb2tpZS5jb22CCyoueXRpbWcuY29t
ggphaS5hbmRyb2lkggthbmRyb2lkLmNvbYINKi5hbmRyb2lkLmNvbYITKi5mbGFz
aC5hbmRyb2lkLmNvbYIEZy5jb4IGKi5nLmNvggZnb28uZ2yCCnd3dy5nb28uZ2yC
FGdvb2dsZS1hbmFseXRpY3MuY29tghYqLmdvb2dsZS1hbmFseXRpY3MuY29tggpn
b29nbGUuY29tghJnb29nbGVjb21tZXJjZS5jb22CFCouZ29vZ2xlY29tbWVyY2Uu
Y29tggp1cmNoaW4uY29tggwqLnVyY2hpbi5jb22CCHlvdXR1LmJlggt5b3V0dWJl
LmNvbYINKi55b3V0dWJlLmNvbYIRbXVzaWMueW91dHViZS5jb22CEyoubXVzaWMu
eW91dHViZS5jb22CFHlvdXR1YmVlZHVjYXRpb24uY29tghYqLnlvdXR1YmVlZHVj
YXRpb24uY29tgg95b3V0dWJla2lkcy5jb22CESoueW91dHViZWtpZHMuY29tggV5
dC5iZYIHKi55dC5iZYIaYW5kcm9pZC5jbGllbnRzLmdvb2dsZS5jb22CFSouYWlz
dHVkaW8uZ29vZ2xlLmNvbTATBgNVHSAEDDAKMAgGBmeBDAECATA2BgNVHR8ELzAt
MCugKaAnhiVodHRwOi8vYy5wa2kuZ29vZy93cjIvNzVyNFp5QTN2QTAuY3JsMIIB
BAYKKwYBBAHWeQIEAgSB9QSB8gDwAHYA1219ENGn9XfCx+lf1wC/+YLJM1pl4dCz
AXMXwMjFaXcAAAGfEr2uawAABAMARzBFAiEAhQIz0f3I8HlOF8WiEgyY6tU1objr
W0sat1EWBbabNd4CIGdpZ4Cia9/39dTrAD8YrYibY3WQiZrruEIagMRwzHzUAHYA
yzj3FYl8hKFEX1vB3fvJbvKaWc1HCmkFhbDLFMMUWOcAAAGfEr2ulgAABAMARzBF
AiA59eNHYQ+sQFGIVkhslWG1mNOjLUCPh7REammLz1nIEQIhAIEaHT2H4WyjzRZ7
5uNIL/tAKOUY4kZlggAUcAwrhou4MA0GCSqGSIb3DQEBCwUAA4IBAQCAd4MI9DNn
7IzJM+7lAgcDmC0oSg76anhebKiUGJbJxBYWdZUIvw/AdLqDn/nlA1s2p7AWgGhD
lXnOpG0hZlmAEz9OA/fbqck2z9+5UH8/B6QfPmxXdboqx0KzC73AYAh9OBd7cnLq
2KdsgPv2AA+vlysSJfgD3PINp5br+GlP2BiCy+XEpT1ydo/uwfT20TI7HuCk1T3h
tIAqH2CWcfIXbGy9PT6ODvG51NiJvK92DvoOEC0PGg/p3hUOfIxiIA83UaJTxR77
MD2ikCestE9X3bdrBlWXBFbDEKNk7F6d94ppNPdAelhBGgdSKq2ezZ5dnZTZKgoR
```


```
du9A7bSQCgod
-----END CERTIFICATE-----
subject=CN=*.google.com
issuer=C=US, O=Google Trust Services, CN=WR2
---
No client certificate CA names sent
Peer signing digest: SHA256
Peer signature type: ecdsa_secp256r1_sha256
Negotiated TLS1.3 group: X25519MLKEM768
---
SSL handshake has read 6249 bytes and written 1632 bytes
Verification: OK
---
New, TLSv1.3, Cipher is TLS_AES_256_GCM_SHA384
Protocol: TLSv1.3
Server public key is 256 bit
This TLS version forbids renegotiation.
Compression: NONE
Expansion: NONE
No ALPN negotiated
Early data was not sent
Verify return code: 0 (ok)
---
DONE
```

WhatWeb


```
{
"success": true,
"technologies": [
{
"name": "Country",
"string": [
"UNITED STATES"
],
"version": []
},
{
"name": "HTTPServer",
"string": [
"gws"
],
"version": []
},
{
"name": "IP",
```

```
"string": [
"172.217.18.110",
"142.251.151.119"
],
"version": []
},
{
"name": "RedirectLocation",
"string": [
"https://www.google.com/"
],
"version": []
},
{
"name": "Title",
"string": [
"301 Moved",
"Google"
],
"version": []
},
{
"name": "UncommonHeaders",
"string": [
"content-security-policy-report-only,alt-svc",
"content-security-policy-report-only,accept-ch,alt-svc"
],
"version": []
},
{
"name": "X-Frame-Options",
"string": [
"SAMEORIGIN"
],
"version": []
},
{
"name": "X-XSS-Protection",
"string": [
"0"
],
"version": []
},
{
"name": "Cookies",
"string": [
"AEC",
"NID",
"__Secure-STRP"
],
"version": []
},
{
"name": "HTML5",
"string": [],
"version": []
},
{
"name": "HttpOnly",
"string": [
"AEC",
"NID"
],
"version": []
},
{
"name": "Script",
"string": [],
"version": []
}
]
}
```

OWASP ZAP


```
{
"@programName": "ZAP",
"@version": "2.17.0",
"@generated": "Sun, 26 Jul 2026 19:01:26",
"created": "2026-07-26T19:01:26.703229018Z",
"insights":[
{
"level": "Info",
"reason": "Informational",
"site": "https://google.com",
"key": "insight.code.2xx",
"description": "Percentage of responses with status code 2xx",
"statistic": "25"
},
{
"level": "Info",
"reason": "Informational",
"site": "https://google.com",
"key": "insight.code.3xx",
"description": "Percentage of responses with status code 3xx",
"statistic": "75"
},
{
"level": "Info",
"reason": "Informational",
"site": "https://google.com",
"key": "insight.endpoint.ctype.text/html",
"description": "Percentage of endpoints with content type text/html",
"statistic": "100"
},
{
"level": "Info",
"reason": "Informational",
"site": "https://google.com",
"key": "insight.endpoint.method.GET",
"description": "Percentage of endpoints with method GET",
"statistic": "100"
},
{
"level": "Info",
"reason": "Informational",
"site": "https://google.com",
"key": "insight.endpoint.total",
"description": "Count of total endpoints",
"statistic": "2"
},
{
"level": "Info",
"reason": "Informational",
"site": "https://google.com",
"key": "insight.response.slow",
"description": "Percentage of slow responses",
"statistic": "100"
}
],
"site":[
{
"@name": "https://google.com",
"@host": "google.com",
"@port": "443",
"@ssl": "true",
"alerts": [
{
"pluginid": "10038",
"alertRef": "10038-1",
"alert": "Content Security Policy (CSP) Header Not Set",
"name": "Content Security Policy (CSP) Header Not Set",
"riskcode": "2",
"confidence": "3",
"riskdesc": "Medium (High)",
```

```
"desc": "<p>Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks, including Cross Site Scripting (XSS) and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page \u2014 covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files.</p>",
"instances":[
{
"id": "8",
"uri": "https://google.com",
"nodeName": "https:\/\/google.com",
"method": "GET",
"param": "",
"attack": "",
"evidence": "",
"otherinfo": ""
}
],
"count": "1",
"systemic": false,
"solution": "<p>Ensure that your web server, application server, load balancer, etc. is configured to set the Content-Security-Policy header.</p>",
"otherinfo": "",
"reference": "<p>https://developer.mozilla.org/en-US/docs/Web/HTTP/Guides/CSP</p><p>https://cheatsheetseries.owasp.org/cheatsheets/Content_Security_Policy_Cheat_Sheet.html</p><p>https://www.w3.org/TR/CSP/</p><p>https://w3c.github.io/webappsec-csp/</p><p>https://web.dev/articles/csp</p><p>https://caniuse.com/#feat=contentsecuritypolicy</p><p>https://content-security-policy.com/</p>",
"cweid": "693",
"wascid": "15",
"sourceid": "1"
},
{
"pluginid": "90003",
"alertRef": "90003",
"alert": "Sub Resource Integrity Attribute Missing",
"name": "Sub Resource Integrity Attribute Missing",
"riskcode": "2",
"confidence": "3",
"riskdesc": "Medium (High)",
"desc": "<p>The integrity attribute is missing on a script or link tag served by an external server. The integrity tag prevents an attacker who have gained access to this server from injecting a malicious content.</p>",
"instances":[
{
"id": "14",
"uri": "https://google.com",
"nodeName": "https:\/\/google.com",
"method": "GET",
"param": "",
"attack": "",
"evidence": "<link href=\"https://www.gstatic.com/og/_/ss/k=og.asy.SYARe0h32hg.R.W.O/m=ll_tdm,adcgm3,ll_fw,abld/excm=/d=1/ed=1/ct=zgms/rs=AA2YrTsnSztlfSYLnqHEirzpExLhvVQKMw\" nonce=\"lMGQ3_HjPawoUOyyz5j_3Q\" id=\"ogb_ss\" media=\"print\" rel=\"stylesheet\">",
"otherinfo": ""
},
{
"id": "13",
"uri": "https://google.com",
"nodeName": "https:\/\/google.com",
"method": "GET",
"param": "",
"attack": "",
"evidence": "<script async=\"\" nonce=\"lMGQ3_HjPawoUOyyz5j_3Q\" src=\"https://www.gstatic.com/og/_/js/k=og.asy.en_US.M_7ghikQAkA.2019.O/rt=j/m=_ac,_awd,ada,lldp,qads,abld/exm=/d=1/ed=1/rs=AA2YrTtJT2GPlx0nJ84RzsS-D9uX1TzAyQ\"></script>",
"otherinfo": ""
}
],
"count": "2",
"systemic": false,
"solution": "<p>Provide a valid integrity attribute to the tag.</p>",
"otherinfo": "",
"reference": "<p>https://developer.mozilla.org/en-US/docs/Web/Security/Defenses/Subresource_Integrity</p>",
"cweid": "345",
```

```
"wascid": "15",
"sourceid": "1"
},
{
"pluginid": "10010",
"alertRef": "10010",
"alert": "Cookie No HttpOnly Flag",
"name": "Cookie No HttpOnly Flag",
"riskcode": "1",
"confidence": "2",
"riskdesc": "Low (Medium)",
"desc": "<p>A cookie has been set without the HttpOnly flag, which means that the cookie can be accessed by JavaScript. If a malicious script can be run on this page then the cookie will be accessible and can be transmitted to another site. If this is a session cookie then session hijacking may be possible.</p>",
"instances":[
{
"id": "10",
"uri": "https://google.com",
"nodeName": "https:\/\/google.com",
"method": "GET",
"param": "__Secure-STRP",
"attack": "",
"evidence": "Set-Cookie: __Secure-STRP",
"otherinfo": ""
}
],
"count": "1",
"systemic": false,
"solution": "<p>Ensure that the HttpOnly flag is set for all cookies.</p>",
"otherinfo": "",
"reference": "<p>https://owasp.org/www-community/HttpOnly</p>",
"cweid": "1004",
"wascid": "13",
"sourceid": "1"
},
{
"pluginid": "10054",
"alertRef": "10054-2",
"alert": "Cookie with SameSite Attribute None",
"name": "Cookie with SameSite Attribute None",
"riskcode": "1",
"confidence": "2",
"riskdesc": "Low (Medium)",
"desc": "<p>A cookie has been set with its SameSite attribute set to \"none\", which means that the cookie can be sent as a result of a 'cross-site' request. The SameSite attribute is an effective counter measure to cross-site request forgery, cross-site script inclusion, and timing attacks.</p>",
"instances":[
{
"id": "11",
"uri": "https://google.com",
"nodeName": "https:\/\/google.com",
"method": "GET",
"param": "NID",
"attack": "",
"evidence": "Set-Cookie: NID",
"otherinfo": ""
}
],
"count": "1",
"systemic": false,
"solution": "<p>Ensure that the SameSite attribute is set to either 'lax' or ideally 'strict' for all cookies.</p>",
"otherinfo": "",
"reference": "<p>https://datatracker.ietf.org/doc/html/draft-ietf-httpbis-cookie-same-site</p>",
"cweid": "1275",
"wascid": "13",
"sourceid": "1"
},
{
"pluginid": "10017",
"alertRef": "10017",
"alert": "Cross-Domain JavaScript Source File Inclusion",
```

```
"name": "Cross-Domain JavaScript Source File Inclusion",
"riskcode": "1",
"confidence": "2",
"riskdesc": "Low (Medium)",
"desc": "<p>The page includes one or more script files from a third-party domain.</p>",
"instances":[
{
"id": "12",
"uri": "https://google.com",
"nodeName": "https:\/\/google.com",
"method": "GET",
"param": "https://www.gstatic.com/og/_/js/k=og.asy.en_US.M_7ghikQAkA.2019.O/rt=j/m=_ac,_awd,ada,lldp,qads,ab
ld/exm=/d=1/ed=1/rs=AA2YrTtJT2GPlx0nJ84RzsS-D9uX1TzAyQ",
"attack": "",
"evidence": "<script async=\"\" nonce=\"lMGQ3_HjPawoUOyyz5j_3Q\" src=\"https://www.gstatic.com/og/_/js/k=og.
asy.en_US.M_7ghikQAkA.2019.O/rt=j/m=_ac,_awd,ada,lldp,qads,abld/exm=/d=1/ed=1/rs=AA2YrTtJT2GPlx0nJ84RzsS-D9u
X1TzAyQ\"></script>",
```

```
"otherinfo": ""
}
],
"count": "1",
"systemic": false,
"solution": "<p>Ensure JavaScript source files are loaded from only trusted sources, and the sources can't be
controlled by end users of the application.</p>",
"otherinfo": "",
"reference": "",
"cweid": "829",
"wascid": "15",
"sourceid": "1"
},
{
"pluginid": "90004",
"alertRef": "90004-2",
"alert": "Cross-Origin-Embedder-Policy Header Missing or Invalid",
"name": "Cross-Origin-Embedder-Policy Header Missing or Invalid",
"riskcode": "1",
"confidence": "2",
"riskdesc": "Low (Medium)",
"desc": "<p>Cross-Origin-Embedder-Policy header is a response header that prevents a document from loading
any cross-origin resources that don't explicitly grant the document permission (using CORP or CORS).</p>",
"instances":[
{
"id": "5",
"uri": "https://google.com",
"nodeName": "https:\/\/google.com",
"method": "GET",
"param": "Cross-Origin-Embedder-Policy",
"attack": "",
"evidence": "",
"otherinfo": ""
}
],
"count": "1",
"systemic": false,
```

```
"solution": "<p>Ensure that the application/web server sets the Cross-Origin-Embedder-Policy header
appropriately, and that it sets the Cross-Origin-Embedder-Policy header to 'require-corp' for
documents.</p><p>If possible, ensure that the end user uses a standards-compliant and modern web browser that
supports the Cross-Origin-Embedder-Policy header
(https://caniuse.com/mdn-http_headers_cross-origin-embedder-policy).</p>",
"otherinfo": "",
"reference":
"<p>https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/Cross-Origin-Embedder-Policy</p>",
"cweid": "693",
"wascid": "14",
"sourceid": "1"
},
{
"pluginid": "90004",
"alertRef": "90004-3",
"alert": "Cross-Origin-Opener-Policy Header Missing or Invalid",
"name": "Cross-Origin-Opener-Policy Header Missing or Invalid",
"riskcode": "1",
```

```
"confidence": "2",
"riskdesc": "Low (Medium)",
"desc": "<p>Cross-Origin-Opener-Policy header is a response header that allows a site to control if others
included documents share the same browsing context. Sharing the same browsing context with untrusted
documents might lead to data leak.</p>",
"instances":[
{
"id": "6",
"uri": "https://google.com",
"nodeName": "https:\/\/google.com",
"method": "GET",
"param": "Cross-Origin-Opener-Policy",
"attack": "",
"evidence": "same-origin-allow-popups",
"otherinfo": ""
}
],
"count": "1",
"systemic": false,
"solution": "<p>Ensure that the application/web server sets the Cross-Origin-Opener-Policy header
appropriately, and that it sets the Cross-Origin-Opener-Policy header to 'same-origin' for
documents.</p><p>'same-origin-allow-popups' is considered as less secured and should be avoided.</p><p>If
possible, ensure that the end user uses a standards-compliant and modern web browser that supports the
Cross-Origin-Opener-Policy header (https://caniuse.com/mdn-http_headers_cross-origin-opener-policy).</p>",
"otherinfo": "",
"reference":
"<p>https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/Cross-Origin-Opener-Policy</p>",
"cweid": "693",
"wascid": "14",
"sourceid": "1"
},
{
"pluginid": "90004",
"alertRef": "90004-1",
"alert": "Cross-Origin-Resource-Policy Header Missing or Invalid",
"name": "Cross-Origin-Resource-Policy Header Missing or Invalid",
"riskcode": "1",
"confidence": "2",
"riskdesc": "Low (Medium)",
"desc": "<p>Cross-Origin-Resource-Policy header is an opt-in header designed to counter side-channels attacks
like Spectre. Resource should be specifically set as shareable amongst different origins.</p>",
"instances":[
{
"id": "4",
"uri": "https://google.com",
"nodeName": "https:\/\/google.com",
"method": "GET",
"param": "Cross-Origin-Resource-Policy",
"attack": "",
"evidence": "",
"otherinfo": ""
}
],
"count": "1",
"systemic": false,
"solution": "<p>Ensure that the application/web server sets the Cross-Origin-Resource-Policy header
appropriately, and that it sets the Cross-Origin-Resource-Policy header to 'same-origin' for all web
pages.</p><p>'same-site' is considered as less secured and should be avoided.</p><p>If resources must be
shared, set the header to 'cross-origin'.</p><p>If possible, ensure that the end user uses a
standards-compliant and modern web browser that supports the Cross-Origin-Resource-Policy header
(https://caniuse.com/mdn-http_headers_cross-origin-resource-policy).</p>",
"otherinfo": "",
"reference":
"<p>https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/Cross-Origin-Embedder-Policy</p>",
"cweid": "693",
"wascid": "14",
"sourceid": "1"
},
{
"pluginid": "10035",
"alertRef": "10035-1",
```

```
"alert": "Strict-Transport-Security Header Not Set",
"name": "Strict-Transport-Security Header Not Set",
"riskcode": "1",
"confidence": "3",
"riskdesc": "Low (High)",
"desc": "<p>HTTP Strict Transport Security (HSTS) is a web security policy mechanism whereby a web server declares that complying user agents (such as a web browser) are to interact with it using only secure HTTPS connections (i.e. HTTP layered over TLS/SSL). HSTS is an IETF standards track protocol and is specified in RFC 6797.</p>",
"instances":[
{
"id": "1",
"uri": "https://google.com",
"nodeName": "https:\/\/google.com",
"method": "GET",
"param": "",
"attack": "",
"evidence": "",
"otherinfo": ""
},
{
"id": "18",
"uri": "https://google.com/robots.txt",
"nodeName": "https:\/\/google.com\/robots.txt",
"method": "GET",
"param": "",
"attack": "",
"evidence": "",
"otherinfo": ""
},
{
"id": "20",
"uri": "https://google.com/sitemap.xml",
"nodeName": "https:\/\/google.com\/sitemap.xml",
"method": "GET",
"param": "",
"attack": "",
"evidence": "",
"otherinfo": ""
}
],
"count": "3",
"systemic": false,
"solution": "<p>Ensure that your web server, application server, load balancer, etc. is configured to enforce Strict-Transport-Security.</p>",
"otherinfo": "",
"reference": "<p>https://cheatsheetseries.owasp.org/cheatsheets/HTTP_Strict_Transport_Security_Cheat_Sheet.html</p><p>https://owasp.org/www-community/Security_Headers</p><p>https://en.wikipedia.org/wiki/HTTP_Strict_Transport_Security</p><p>https://caniuse.com/stricttransportsecurity</p><p>https://datatracker.ietf.org/doc/html/rfc6797</p>",
"cweid": "319",
"wascid": "15",
"sourceid": "6"
},
{
"pluginid": "10021",
"alertRef": "10021",
"alert": "X-Content-Type-Options Header Missing",
"name": "X-Content-Type-Options Header Missing",
"riskcode": "1",
"confidence": "2",
"riskdesc": "Low (Medium)",
"desc": "<p>The Anti-MIME-Sniffing header X-Content-Type-Options was not set to 'nosniff'. This allows older versions of Internet Explorer and Chrome to perform MIME-sniffing on the response body, potentially causing the response body to be interpreted and displayed as a content type other than the declared content type. Current (early 2014) and legacy versions of Firefox will use the declared content type (if one is set), rather than performing MIME-sniffing.</p>",
"instances":[
{
"id": "15",
"uri": "https://google.com",
"nodeName": "https:\/\/google.com",
"method": "GET",
"param": "x-content-type-options",
```

```
"attack": "",
"evidence": "",
"otherinfo": "This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type.\nAt \"High\" threshold this scan rule will not alert on client or server error responses."
}
],
"count": "1",
"systemic": false,
"solution": "<p>Ensure that the application/web server sets the Content-Type header appropriately, and that it sets the X-Content-Type-Options header to 'nosniff' for all web pages.</p><p>If possible, ensure that the end user uses a standards-compliant and modern web browser that does not perform MIME-sniffing at all, or that can be directed by the web application/web server to not perform MIME-sniffing.</p>",
"otherinfo": "<p>This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type.</p><p>At \"High\" threshold this scan rule will not alert on client or server error responses.</p>",
"reference": "<p>https://learn.microsoft.com/en-us/previous-versions/windows/internet-explorer/ie-developer/compatibility/gg622941(v=vs.85)</p><p>https://owasp.org/www-community/Security_Headers</p>",
"cweid": "693",
"wascid": "15",
"sourceid": "1"
},
{
"pluginid": "10038",
"alertRef": "10038-3",
"alert": "Content Security Policy (CSP) Report-Only Header Found",
"name": "Content Security Policy (CSP) Report-Only Header Found",
"riskcode": "0",
"confidence": "3",
"riskdesc": "Informational (High)",
"desc": "<p>The response contained a Content-Security-Policy-Report-Only header, this may indicate a work-in-progress implementation, or an oversight in promoting pre-Prod to Prod, etc.</p><p></p><p>Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks, including Cross Site Scripting (XSS) and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page \u2014 covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files.</p>",
"instances":[
{
"id": "9",
"uri": "https://google.com",
"nodeName": "https:\/\/google.com",
"method": "GET",
"param": "",
"attack": "",
"evidence": "",
"otherinfo": ""
}
],
"count": "1",
"systemic": false,
"solution": "<p>Ensure that your web server, application server, load balancer, etc. is configured to set the Content-Security-Policy header.</p>",
"otherinfo": "",
"reference": "<p>https://www.w3.org/TR/CSP2/</p><p>https://w3c.github.io/webappsec-csp/</p><p>https://caniuse.com/#feat=contentsecuritypolicy</p><p>https://content-security-policy.com/</p>",
"cweid": "693",
"wascid": "15",
"sourceid": "1"
},
{
"pluginid": "10049",
"alertRef": "10049-1",
"alert": "Non-Storable Content",
"name": "Non-Storable Content",
"riskcode": "0",
"confidence": "2",
"riskdesc": "Informational (Medium)",
"desc": "<p>The response contents are not storable by caching components such as proxy servers. If the
```

```
response does not contain sensitive, personal or user-specific information, it may benefit from being stored
and cached, to improve performance.</p>",
"instances":[
{
"id": "3",
"uri": "https://google.com",
"nodeName": "https:\/\/google.com",
"method": "GET",
"param": "",
"attack": "",
"evidence": "private",
"otherinfo": ""
}
],
"count": "1",
"systemic": false,
"solution": "<p>The content may be marked as storable by ensuring that the following conditions are
satisfied:</p><p>The request method must be understood by the cache and defined as being cacheable (\"GET\",
\"HEAD\", and \"POST\" are currently defined as cacheable)</p><p>The response status code must be understood
by the cache (one of the 1XX, 2XX, 3XX, 4XX, or 5XX response classes are generally understood)</p><p>The
\"no-store\" cache directive must not appear in the request or response header fields</p><p>For caching by
\"shared\" caches such as \"proxy\" caches, the \"private\" response directive must not appear in the
response</p><p>For caching by \"shared\" caches such as \"proxy\" caches, the \"Authorization\" header field
must not appear in the request, unless the response explicitly allows it (using one of the
\"must-revalidate\", \"public\", or \"s-maxage\" Cache-Control response directives)</p><p>In addition to the
conditions above, at least one of the following conditions must also be satisfied by the response:</p><p>It
must contain an \"Expires\" header field</p><p>It must contain a \"max-age\" response directive</p><p>For
\"shared\" caches such as \"proxy\" caches, it must contain a \"s-maxage\" response directive</p><p>It must
contain a \"Cache Control Extension\" that allows it to be cached</p><p>It must have a status code that is
defined as cacheable by default (200, 203, 204, 206, 300, 301, 404, 405, 410, 414, 501).</p>",
"otherinfo": "",
"reference": "<p>https://datatracker.ietf.org/doc/html/rfc7234</p><p>https://datatracker.ietf.org/doc/html/r
fc7231</p><p>https://www.w3.org/Protocols/rfc2616/rfc2616-sec13.html</p>",
"cweid": "524",
"wascid": "13",
"sourceid": "1"
},
{
"pluginid": "10015",
"alertRef": "10015",
```

```
"alert": "Re-examine Cache-control Directives",
"name": "Re-examine Cache-control Directives",
"riskcode": "0",
"confidence": "1",
"riskdesc": "Informational (Low)",
"desc": "<p>The cache-control header has not been set properly or is missing, allowing the browser and
proxies to cache content. For static assets like css, js, or image files this might be intended, however, the
resources should be reviewed to ensure that no sensitive content will be cached.</p>",
"instances":[
{
"id": "7",
"uri": "https://google.com",
"nodeName": "https:\/\/google.com",
"method": "GET",
"param": "cache-control",
"attack": "",
"evidence": "private, max-age=0",
"otherinfo": ""
}
],
"count": "1",
"systemic": false,
"solution": "<p>For secure content, ensure the cache-control HTTP header is set with \"no-cache, no-store,
must-revalidate\". If an asset should be cached consider setting the directives \"public, max-age,
immutable\".</p>",
"otherinfo": "",
"reference": "<p>https://cheatsheetseries.owasp.org/cheatsheets/Session_Management_Cheat_Sheet.html#web-cont
ent-caching</p><p>https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/Cache-Control</p><p>ht
tps://grayduck.mn/2021/09/13/cache-control-recommendations/</p>",
"cweid": "525",
"wascid": "13",
"sourceid": "1"
},
{
```

```
"pluginid": "10050",
"alertRef": "10050-2",
"alert": "Retrieved from Cache",
"name": "Retrieved from Cache",
"riskcode": "0",
"confidence": "2",
"riskdesc": "Informational (Medium)",
"desc": "<p>The content was retrieved from a shared cache. If the response data is sensitive, personal or
user-specific, this may result in sensitive information being leaked. In some cases, this may even result in
a user gaining complete control of the session of another user, depending on the configuration of the caching
components in use in their environment. This is primarily an issue where caching servers such as \"proxy\"
caches are configured on the local network. This configuration is typically found in corporate or educational
environments, for instance.</p>",
"instances":[
{
"id": "17",
"uri": "https://google.com/robots.txt",
"nodeName": "https:\/\/google.com\/robots.txt",
"method": "GET",
"param": "",
"attack": "",
"evidence": "Age: 1686",
"otherinfo": "The presence of the 'Age' header indicates that a HTTP/1.1 compliant caching server is in use."
}
],
"count": "1",
"systemic": false,
"solution": "<p>Validate that the response does not contain sensitive, personal or user-specific information.
If it does, consider the use of the following HTTP response headers, to limit, or prevent the content being
stored and retrieved from the cache by another user:</p><p>Cache-Control: no-cache, no-store,
must-revalidate, private</p><p>Pragma: no-cache</p><p>Expires: 0</p><p>This configuration directs both HTTP
1.0 and HTTP 1.1 compliant caching servers to not store the response, and to not retrieve the response
(without validation) from the cache, in response to a similar request.</p>",
"otherinfo": "<p>The presence of the 'Age' header indicates that a HTTP/1.1 compliant caching server is in
use.</p>",
"reference": "<p>https://datatracker.ietf.org/doc/html/rfc7234</p><p>https://datatracker.ietf.org/doc/html/r
fc7231</p><p>https://www.rfc-editor.org/rfc/rfc9110.html</p>",
"cweid": "525",
"wascid": "-1",
"sourceid": "7"
},
{
"pluginid": "10112",
"alertRef": "10112",
"alert": "Session Management Response Identified",
"name": "Session Management Response Identified",
"riskcode": "0",
"confidence": "2",
"riskdesc": "Informational (Medium)",
"desc": "<p>The given response has been identified as containing a session management token. The 'Other Info'
field contains a set of header tokens that can be used in the Header Based Session Management Method. If the
request is in a context which has a Session Management Method set to \"Auto-Detect\" then this rule will
change the session management to use the tokens identified.</p>",
"instances":[
{
"id": "2",
"uri": "https://google.com",
"nodeName": "https:\/\/google.com",
"method": "GET",
"param": "NID",
"attack": "",
"evidence": "NID",
"otherinfo": "cookie:NID\ncookie:__Secure-STRP\ncookie:AEC"
}
],
"count": "1",
"systemic": false,
"solution": "<p>This is an informational alert rather than a vulnerability and so there is nothing to
fix.</p>",
"otherinfo": "<p>cookie:NID</p><p>cookie:__Secure-STRP</p><p>cookie:AEC</p>",
"reference": "<p>https://www.zaproxy.org/docs/desktop/addons/authentication-helper/session-mgmt-id/</p>",
"cweid": "-1",
```

```
"wascid": "-1",
"sourceid": "1"
},
{
"pluginid": "10049",
"alertRef": "10049-3",
"alert": "Storable and Cacheable Content",
"name": "Storable and Cacheable Content",
"riskcode": "0",
"confidence": "2",
"riskdesc": "Informational (Medium)",
"desc": "<p>The response contents are storable by caching components such as proxy servers, and may be retrieved directly from the cache, rather than from the origin server by the caching servers, in response to similar requests from other users. If the response data is sensitive, personal or user-specific, this may result in sensitive information being leaked. In some cases, this may even result in a user gaining complete control of the session of another user, depending on the configuration of the caching components in use in their environment. This is primarily an issue where \"shared\" caching servers such as \"proxy\" caches are configured on the local network. This configuration is typically found in corporate or educational environments, for instance.</p>",
"instances":[
{
"id": "0",
"uri": "https://google.com",
"nodeName": "https:\/\/google.com",
"method": "GET",
"param": "",
"attack": "",
"evidence": "max-age=2592000",
```

```
"otherinfo": ""
},
{
"id": "16",
"uri": "https://google.com/robots.txt",
"nodeName": "https:\/\/google.com\/robots.txt",
"method": "GET",
"param": "",
"attack": "",
"evidence": "max-age=1800",
"otherinfo": ""
},
{
"id": "19",
"uri": "https://google.com/sitemap.xml",
"nodeName": "https:\/\/google.com\/sitemap.xml",
"method": "GET",
"param": "",
"attack": "",
"evidence": "max-age=1800",
"otherinfo": ""
}
],
"count": "3",
"systemic": false,
"solution": "<p>Validate that the response does not contain sensitive, personal or user-specific information. If it does, consider the use of the following HTTP response headers, to limit, or prevent the content being stored and retrieved from the cache by another user:</p><p>Cache-Control: no-cache, no-store, must-revalidate, private</p><p>Pragma: no-cache</p><p>Expires: 0</p><p>This configuration directs both HTTP 1.0 and HTTP 1.1 compliant caching servers to not store the response, and to not retrieve the response (without validation) from the cache, in response to a similar request.</p>",
"otherinfo": "",
"reference": "<p>https://datatracker.ietf.org/doc/html/rfc7234</p><p>https://datatracker.ietf.org/doc/html/rfc7231</p><p>https://www.w3.org/Protocols/rfc2616/rfc2616-sec13.html</p>",
"cweid": "524",
"wascid": "13",
"sourceid": "6"
}
]
}
],
```

```
"sequences":[
]
```

```
}
```


NVD

Aucune sortie brute disponible.

Preuves techniques complètes disponibles en export JSON depuis l’historique des scans (scan ID : 124)